The step for running the vulnerability scan is based on an action provided by Anchore, the company behind grype. In listing 3.22, we do not fail the workflow if serious vulnerabilities are discovered. However, you can find the scanning results in the Security section of your catalog-service GitHub repository.

At the time of writing, there is no high or critical vulnerability in the Catalog Service project, but things might be different in the future. If that's the case, consider using the latest available security patches for the affected dependencies. For the sake of the example, and because I don't want to disrupt your learning journey, I decided not to make the build fail on finding vulnerabilities. In a real-world scenario, however, I recommend you configure and tune grype carefully and according to your company policies regarding supply chain security, and make the workflow fail if the result is not compliant (setting the `fail-build` property to `true`). For more information, refer to the official grype documentation (https://github.com/anchore/grype).

After scanning the Java project for vulnerabilities, we also included a step to fetch the security report generated by grype and upload it to GitHub, independently of whether the build succeeds or not. If any security vulnerability is found, you can see the results in the Security tab of your GitHub repository page (figure 3.10).